

Triage Playbook and Framework for the Nexus Logistics Breach

Daniel Pereira, Diogo Larangeira, Maria Inês Tovar, Rodrigo Rodrigues

Department of Informatics Engineering
Master in Informatics Security - Security Audit
University of Coimbra, 2025/2026

Abstract—This document presents a dual-OS live triage playbook and framework designed for the Nexus Logistics breach scenario, in which a finance workstation (FIN-WKST-42, Windows 11) initiated an anomalous SSH session to a production database server (UBUNTU-DB-01, Ubuntu 22.04 LTS), followed by massive outbound data exfiltration. Operating under strict business continuity constraints (250,000 EUR/h if production servers are taken offline) and limited analyst capacity, the playbook defines an order of volatility, targeted artifact collection procedures for both operating systems, supporting forensic infrastructure, and chain of custody controls. All steps are actionable by a junior analyst without requiring full-disk imaging.

Index Terms—Digital forensics, Incident response, Live Triage, Windows forensics, Linux forensics, Chain of custody

I. INTRODUCTION

Nexus Logistics is a global supply-chain provider whose digital infrastructure comprises 300 Windows 11 corporate workstations and approximately 20 Ubuntu 22.04 LTS servers running routing APIs, inventory databases, and a customer-facing portal. A compromise anywhere in this tightly coupled environment can propagate rapidly, and every minute of unplanned server downtime costs the company an estimated 250,000 EUR in halted global shipping operations. Balancing forensic rigour with business continuity is therefore not an academic concern, it is the central operational constraint of any incident response in this environment.

At 02:00 AM on a Sunday, the automated Network Intrusion Detection System (NIDS) triggered a high-severity alert: a finance workstation (FIN-WKST-42, Windows 11) had initiated an anomalous, high-volume SSH connection to the primary production database server (UBUNTU-DB-01, Ubuntu 22.04 LTS). Shortly after, a massive spike in outbound data transfer was detected from UBUNTU-DB-01 to an unclassified external IP address located overseas. Executive leadership immediately prohibited taking any Ubuntu server offline, and the response team, a lead analyst and one junior colleague, lacked the time and storage capacity to perform full-disk bit-stream images across the affected subnet.

Under these constraints, traditional forensic acquisition methods such as full-disk imaging with `dd` or `.E01` are not operationally viable. The appropriate response is a **Live Triage Strategy** that, following the evidence collection principles of RFC 3227 [7], prioritizes volatile data in order of ephemeral-

ity, preserves critical artifacts before they are overwritten or lost, and minimizes disruption to production services.

This report presents a dual-OS **Triage Playbook** designed for exactly this type of crisis. Its objective is to provide clear, actionable instructions that a junior analyst can execute immediately under high-stress conditions without prior familiarity with the environment.

The document is organized as follows: Section II defines the strategic prioritization and order of volatility for both operating systems; Sections III and IV detail the targeted artifact collection procedures for Windows 11 and Ubuntu 22.04 respectively; Section V describes the supporting forensic infrastructure; and Section VI establishes the data integrity controls and chain of custody workflow, aligned with ISO/IEC 27037:2012 [8], to ensure that all acquired evidence remains reliable, traceable, and admissible.

II. STRATEGIC PRIORITIZATION & ORDER OF VOLATILITY

A. Order of Engagement and Role Assignment

The triage begins on **UBUNTU-DB-01**, the source of the confirmed data exfiltration. This server represents the live crime scene: the outbound transfer is ongoing, and volatile evidence (network sockets, process memory, and kernel state) will be destroyed the moment the connection drops or the attacker cleans up. The Windows workstation FIN-WKST-42, while the likely initial compromise vector, is a comparatively static artifact; its memory and registry state are far more stable over the same timeframe. That said, the SSH session could also originate from stolen credentials replayed through the workstation rather than a direct compromise of FIN-WKST-42 itself; this hypothesis is tested during Windows memory and event log analysis.

The executive constraint forbids rebooting or isolating Ubuntu servers. Live triage on a running system is therefore not a compromise but the only operationally viable methodology under the stated business-continuity requirement.

For the **role assignment**, given that the team consists of two analysts, the **lead analyst** takes responsibility for UBUNTU-DB-01, as the production server requires experienced judgement regarding which commands to run on a live system without disrupting services. The **junior analyst** is dispatched concurrently to FIN-WKST-42, where the collection process is largely automated through pre-configured toolkits (KAPE and WinPmem), reducing the risk of error. This parallel execution

model ensures that volatile evidence is captured on both systems simultaneously within the first hour of the response.

B. Containment vs. Evidence Preservation

The ongoing exfiltration from UBUNTU-DB-01 to the external IP poses an immediate dilemma: blocking the connection at the perimeter firewall would stop data loss but would also destroy active network sockets (a Priority 1 volatile artifact) and could alert the attacker, potentially triggering anti-forensic routines. Our strategy follows a deliberate three-phase sequence: **first**, deploy the passive packet-capture TAP on the server uplink so that full-content PCAP of the exfiltration stream is preserved; **then**, complete the Priority 1 through 3 volatile captures (network state, process tree, open sockets); and **only then**, request the network operations team to block the external IP at the perimeter firewall. This sequencing maximises both forensic value and containment speed, with an estimated window of 10 to 15 minutes between alert and block.

C. Estimated Response Timeline

Table I presents the target timeline for the first 60 minutes of the response, showing parallel activities for both analysts. Note that on UBUNTU-DB-01, the lead analyst captures active network sockets (P3) before the process list (P1), deviating from the theoretical order of volatility. This is a deliberate operational decision: because the exfiltration connection may drop at any moment, the analyst prioritises the most time-critical evidence (the live socket linking the attacker IP to a local process) before proceeding to the broader process enumeration.

TABLE I
TARGET RESPONSE TIMELINE (FIRST 60 MINUTES)

Min	Lead (UBUNTU-DB-01)	Junior (FIN-WKST-42)
0–5	Deploy TAP on server uplink; begin <code>ss/netstat</code> capture	Reassign switch port to forensic VLAN
5–10	Capture process tree, open file handles, kernel modules	Launch WinPmem memory acquisition to FCS
10–15	Request perimeter firewall block via network ops	Capture network state (<code>netstat -anob</code> , ARP)
15–30	Load LiME; stream RAM to FCS over TCP	Run KAPE with LiveResponse + EvidenceOfExecution targets
30–45	Collect logs (<code>auth.log</code> , <code>bash_history</code> , <code>authorized_keys</code>)	Collect <code>.evtx</code> channels and SSH artifacts
45–60	Run UAC <code>ir_triage</code> profile; verify hashes	Transfer KAPE output to FCS; verify hashes

D. Order of Volatility Matrix

Table II defines the collection order for both platforms, following the RFC 3227 principle that the most ephemeral data must be captured first [7].

TABLE II
ORDER OF VOLATILITY: DUAL-OS MATRIX

P	Ubuntu 22.04 (UBUNTU-DB-01)	Windows 11 (FIN-WKST-42)
1	Running process list + process memory	Running processes + process memory
2	System time, ARP cache, routing table	System time, ARP/DNS cache
3	Active network connections (<code>ss/netstat</code>)	Active TCP/UDP connections
4	Loaded kernel modules (rootkit check)	Loaded DLLs, handles, drivers
5	Open file handles (<code>lsiof</code>)	Open handles (Sysinternals)
6	Logged-in users, shell histories	Logged-in sessions, PS history
7	<code>/var/log</code> auth & syslog	Windows Event Logs (<code>.evtx</code>)
8	<code>/tmp</code> , <code>/dev/shm</code> , cron jobs	\$TEMP, Prefetch, Amcache
9	Filesystem timestamps (<code>stat</code>)	MFT timestamps, LNK, Jump Lists
10	User account state (<code>/etc/passwd</code>)	Local users, registry hives

E. Business Justification and Escalation Criteria

Live triage on UBUNTU-DB-01 eliminates the 250,000 EUR/h outage cost while capturing all forensically relevant volatile evidence. Full-disk imaging is deferred to a scheduled maintenance window. FIN-WKST-42 can be network-isolated at the switch level (VLAN reassignment) without a reboot, preserving its memory state while preventing further lateral movement. This two-track approach (server-first live triage with simultaneous workstation memory acquisition) maximises evidence coverage within the resource constraint of two analysts.

The **escalation criteria** are defined as follows. During the initial triage, the Velociraptor server is used to run IOC-based hunts across all remaining endpoints (300 workstations and 19 additional Ubuntu servers). If the hunt identifies more than two additional compromised systems, or if evidence of domain-level credential compromise is found (e.g., a compromised service account or Pass-the-Hash artifacts), the lead analyst escalates to a Level 2 incident response, requesting external CSIRT support and notifying executive management. Given that Nexus Logistics qualifies as an Essential Entity under NIS2 (Article 21, incident handling), the incident must be reported to the competent national authority within 24 hours (early warning) and 72 hours (incident notification); if any financial services are involved, DORA Article 13 also applies. Forensic readiness directly supports these obligations by ensuring the notification is evidence-based rather than guesswork.

III. WINDOWS WORKSTATION TRIAGE (FIN-WKST-42)

A finance workstation initiating an SSH session to a production database server is inherently anomalous, as this type of endpoint would typically have no legitimate reason to use SSH. This anomaly is itself a strong indicator of compromise or credential misuse and guides the artifact selection below toward SSH-related evidence, execution history, and potential initial access vectors such as phishing.

A. Volatile Data Capture

Full RAM is captured first using **WinPmem** [1], a kernel-driver-based memory imager that reads physical memory with minimal process footprint, with output streamed directly to the forensic collection server (FCS) over the forensic VLAN to avoid writing to the local disk. Immediately after the memory image is complete, active TCP/UDP connections with owning process IDs are captured via `netstat -anob`, together with the ARP cache and full IP configuration, each redirected to a text file on the forensic share. Running processes, loaded DLLs, and parent-child relationships are then captured using **Sysinternals PsList**, with **ProcDump** used to extract the memory of any suspicious processes identified during this phase.

The exact command sequences for all volatile captures are provided in `scripts/win_volatile.ps1` in the supplementary ZIP package.

B. Persistence & Execution Artifacts

The following registry hives and artifact locations are extracted using **KAPE** [2] (Kroll Artifact Parser and Extractor) with the `Windows_LiveResponse` and `EvidenceOfExecution` target modules:

- `Run/RunOnce` keys under `HKLM` and `HKCU`: autorun persistence
- `HKLM\SYSTEM\CurrentControlSet\Services`: malicious services or drivers
- **Amcache.hve**: records first execution time of binaries
- **ShimCache** (AppCompatCache in `SYSTEM` hive): execution timestamps
- **Prefetch files** (`*.pf`): execution artefacts with run counts
- **Scheduled Tasks**: attacker persistence via task scheduler
- **Recent LNK files** and **Jump Lists**: user activity and lateral pivot evidence
- **Browser artifacts** (history, downloads, cache): if the initial compromise was delivered via phishing, the browser history and download records may reveal the malicious URL or attachment that served as the entry point

SSH-specific artifacts are also targeted: `known_hosts` under the user profile's `.ssh` directory, OpenSSH client logs under `ProgramData\ssh\logs`, and OpenSSH binary execution evidence in `Prefetch`.

C. Event Log Collection

The following `.evtx` channels are collected in their entirety and parsed offline on the FCS using **Hayabusa** [3] to surface SIGMA-rule detections for lateral movement and credential abuse:

- `Security.evtx`: EID 4624/4625 (logon/fail), 4648 (explicit credential use), 4688 (process creation with command line), 4720/4732 (account/group modification)
- `System.evtx`: service installation (EID 7045), unexpected shutdowns
- `PowerShell/Operational.evtx`: EID 4103/4104 (script block and module logging)

- `Sysmon/Operational.evtx`: process creation, network connections, DNS queries (if Sysmon deployed)
- `TerminalServices-RDPClient/Operational.evtx`: outbound RDP evidence
- `TaskScheduler/Operational.evtx`: task creation and execution
- `OpenSSH/Operational.evtx`: SSH session details from the native client

D. Tooling

The Windows triage is automated via a **KAPE** compound target configuration deployed from a write-protected USB drive or network share. KAPE orchestrates artifact collection and outputs a structured evidence package. To minimise resource consumption on the compromised endpoint, heavy analysis tools such as Hayabusa are *not* run inline; `.evtx` logs are extracted and processed entirely off-system on the FCS. The Velociraptor [9] Windows agent, if pre-deployed, pushes the KAPE output and WinPmem image directly to the FCS; otherwise the analyst transfers via SFTP from the forensic USB.

IV. UBUNTU SERVER TRIAGE (UBUNTU-DB-01)

A. Live Volatile Data Capture

All commands are executed as `root` via a read-only, statically-compiled triage binary bundle (**UAC** [4] or a custom bash collector) mounted from a forensic USB or pulled via SCP from the forensic server, ensuring no attacker-controlled binaries on `$PATH` are invoked. Output is piped directly to the FCS via an NFS/SFTP mount at `/mnt/forensic`, so that no triage output is written to local disk on the target system.

The collection follows the order of volatility defined in Table II: (1) the running process list via `ps`, `top`, and `ls -la /proc/*/exe`; (2) system time, ARP cache, and routing table; (3) active network sockets and connections via `ss` and `netstat`; (4) kernel module integrity by comparing `lsmod` output against `/proc/modules` to detect hidden modules indicative of a kernel-level rootkit, with a SHA-256 hash of the running kernel image for baseline verification; and (5) open file handles via `lssof`.

Memory acquisition is performed using **LiME** (Linux Memory Extractor) [5], loaded as a kernel module that streams physical RAM over TCP directly to the FCS. As a modern alternative optimised for Linux server fleets, **Microsoft AVML** [6] (a Rust-based acquisition tool that does not require a matching kernel module) may also be used and is kept in the toolkit as a fallback for cases where a pre-built LiME module for the running kernel is not available. It is important to note that LiME must be cross-compiled against the *exact* running kernel version of UBUNTU-DB-01 prior to deployment; a pre-built module matching the server's kernel should be maintained in the forensic toolkit. Additionally, loading a kernel module inherently modifies kernel state, so all lighter-weight volatile captures (P1 through P5) are completed *before* LiME is inserted. The resulting image should be treated as a memory *smear* rather than a perfect snapshot, since the acquisition

tool itself occupies memory pages and may overwrite small fragments of evidence during the capture.

The exact command sequences and their expected output formats are provided in `scripts/ubuntu_triage.sh` in the supplementary ZIP package.

B. Log Analysis

The following log paths are collected and cross-referenced against the SSH session timestamps from the NIDS alert (02:00 AM Sunday) to reconstruct the attacker’s command sequence:

- `/var/log/auth.log`: SSH logins, sudo activity, PAM authentication; primary source for attacker entry point
- `/var/log/syslog`: general system events, cron execution
- `/var/log/kern.log`: kernel messages, module loads, interface changes
- `/var/log/dpkg.log`: unexpected package installations by attacker
- Database query logs (`/var/log/postgresql/*.log` or `/var/log/mysql/`): evidence of SQL-based data extraction
- `/var/log/nginx/access.log` and `error.log`: web-facing portal access patterns
- `.bash_history` for root and all user accounts (checking for `HISTFILE=/dev/null` anti-forensics)
- `authorized_keys` files under `/root/.ssh/` and `/home/*/.ssh/`: backdoor SSH keys
- Contents of `/tmp`, `/dev/shm`, and `/var/tmp`: dropper and staging areas

Logs are collected and parsed with UAC, then triaged with timeline correlation on the FCS.

C. Filesystem Timestamps and User Account Check

Filesystem timestamps are captured using `stat` on key directories (`/etc`, `/root`, `/tmp`, `/var/tmp`, `/home/*`) and a `find`-based scan of files modified or status-changed within the last seven days, providing a timeline of attacker activity around the NIDS alert window.

The triage also captures `/etc/passwd`, `/etc/shadow`, and `/etc/sudoers` (including `sudoers.d/` drop-ins), together with login records via `lastlog`, `last -aFwx`, and `who`. Local user accounts with UID in the 1000–60000 range are enumerated, and a filesystem-wide scan for SUID binaries is performed. Indicators of compromise include: new UID/GID 0 accounts, `sudoers.d/` entries predating the incident, and unexpected SUID binaries. The full command listing is provided in `scripts/ubuntu_triage.sh`.

D. Tooling

The primary automation tool is **UAC (Unix Artifact Collector)** [4], an open-source, agentless bash framework that collects a comprehensive artifact set from live Linux systems without installation. UAC is copied to a RAM-backed mount (`tmpfs`) to avoid disk writes on the target and executed

with the `ir_triage` profile, which covers all volatile and log categories above. A supplementary custom bash script is included in the ZIP package to capture database-specific artifacts and network flow data not covered by the default UAC profile.

V. SUPPORTING INFRASTRUCTURE

A. Support Services and Servers

A dedicated **Forensic Collection Server (FCS)** is the hub of the forensic infrastructure. Table III summarises all required services and their specifications.

TABLE III
FORENSIC INFRASTRUCTURE COMPONENTS

Component	Role	Key Requirements
FCS	Central evidence repository; runs Velociraptor server	Isolated VLAN; RAID-6 (≥ 8 TB); hardened Ubuntu; no internet
Velociraptor	Remote live triage orchestration and artifact collection	TLS mutual auth; persistent agents
NTP Server	Accurate timestamps across all evidence	Stratum-1 internal; GPS-disciplined preferred
SIEM / Log Aggregator	Centralised log ingestion (syslog, WEF)	Pre-deployed; tamper-evident storage
SFTP / SMB Share	Encrypted evidence transfer from end-points	Certificate auth; write-once mount
Analysis Workstation	Offline analysis (Autopsy, Volatility3, Hayabusa)	Air-gapped; dedicated GPU
Packet Capture TAP	Full-packet PCAP of UBUNTU-DB-01 egress	Passive TAP on uplink; tcpdump/Zeek to FCS

B. Connection to Servers and Workstations

UBUNTU-DB-01 connects to the FCS via a dedicated forensic VLAN interface. UAC output and LiME memory streams are transferred over SFTP/TCP to the FCS without transiting the production network. The Velociraptor [9] agent, pre-deployed on all Ubuntu servers, allows the lead analyst to issue artifact collection hunts remotely from the FCS without SSH access to the target.

FIN-WKST-42 is network-isolated by reassigning its switch port to a forensic VLAN (preserving memory state). The Velociraptor Windows agent pushes KAPE output and WinPmem memory image directly to the FCS over the forensic VLAN. If Velociraptor is not pre-deployed, the analyst boots from a forensic USB containing the KAPE bundle and transfers over SFTP.

All other workstations are evaluated by querying the Velociraptor server for anomalous network connections or

process executions matching the attacker’s indicators of compromise (IOCs), enabling rapid scoping without touching each machine individually.

The **Syslog Aggregator** receives pre-incident log streams from all 20 Ubuntu servers via rsyslog over TLS, providing a tamper-evident historical baseline. The **Packet Capture Sensor** operates passively on the core switch uplink and requires no agent deployment.

VI. DATA INTEGRITY, STORAGE, & CHAIN OF CUSTODY

A. Secure Evidence Transfer

All collected triage data is transferred exclusively to the FCS over the isolated forensic VLAN using **SFTP with certificate-based authentication** or, for streaming memory acquisition, over a dedicated **LiME TCP stream** with no intermediate disk writes on the source system. Evidence shares on the FCS are mounted *write-once* on the collection endpoints, preventing accidental or adversarial modification.

For field scenarios requiring physical media, evidence is written to **AES-256 hardware-encrypted drives** (e.g., Apricorn Aegis), which are sealed immediately after collection.

B. Cryptographic Data Integrity

Integrity is guaranteed by a **dual-hash chain** (MD5 + SHA-256) applied at every transfer stage, following ISO/IEC 27037:2012 guidelines [8]:

- 1) **At collection:** both MD5 and SHA-256 hashes are computed on the source system before transfer and recorded alongside the artifact.
- 2) **At receipt (FCS):** both hashes are recomputed on arrival and compared against the transmitted values. A mismatch on either hash halts the transfer and triggers an alert.
- 3) **At analysis:** before opening any file, the analyst recomputes and logs both hashes against the original record. All hashes are stored in a tamper-evident append-only log (kernel `chattr +a`).

SHA-256 is the primary collision-resistant hash; MD5 is computed in parallel as a secondary verification. Although MD5 alone is no longer considered secure due to known collision vulnerabilities, requiring both hashes to match simultaneously mathematically eliminates any plausible risk of accidental or intentional collision, while also providing compatibility with legacy forensic tooling. The entire toolset (KAPE, WinPmem, Volatility3, UAC, LiME, Hayabusa, Velociraptor) consists of peer-reviewed, industry-standard tools whose outputs satisfy forensic admissibility criteria such as the Daubert Standard.

C. Chain of Custody Workflow

Every artifact acquisition follows a rapid CoC workflow. Upon collecting each artifact, the analyst completes the following fields (electronic form in the case management system; paper backup if systems unavailable):

Case ID	: NLB-2026-001
Exhibit ID	: [e.g., NLB-001-W-MEM-01]
System	: [FIN-WKST-42 UBUNTU-DB-01]

Artifact Type	: [RAM EventLog NetworkCapture ...]
Collected by	: [Analyst Name]
Date/Time UTC	: [ISO 8601]
NTP Source	: [192.168.100.1 stratum 1]
MD5	: [computed hash]
SHA-256	: [computed hash]
Storage Dest.	: [FCS path or encrypted drive serial]
Witness	: [Junior Analyst Name]

For the **transfer verification**, upon arrival at FCS, the FCS operator recomputes both hashes, records the results, and signs the receipt in the case management log.

Regarding the **access log**, the FCS enforces mandatory access logging via `auditd`. Every file access is recorded with the analyst identity, timestamp, and operation type.

During **exhibit sealing**, once verified, the evidence directory is made immutable (`chattr -R +i`) and a final manifest file is generated listing all exhibit IDs, hashes, and custody entries. This manifest is **digitally signed** using the lead analyst’s GPG key.

Finally, for **reporting**, the signed manifest, all CoC records, and the triage output packages are transferred to the legal team and preserved for potential litigation. No analysis copies are made without logging a new CoC entry for each derived exhibit.

CONCLUSION

This playbook provides a structured, dual-OS triage methodology that operates entirely within the operational and resource constraints of the Nexus Logistics breach. By prioritising live volatile evidence on the production Ubuntu server, parallelising Windows workstation acquisition, and anchoring all evidence in a cryptographically verifiable chain of custody, the framework maximises forensic value while eliminating production downtime and the need for full-disk imaging. The explicit containment sequencing (capture first, then block) addresses the ongoing exfiltration without sacrificing volatile evidence, and the built-in escalation criteria ensure that the response scales appropriately if the breach extends beyond the two initially identified systems. The framework also supports regulatory notification obligations under NIS2 and DORA by ensuring that early warnings are evidence-based. Pre-deployed infrastructure (Velociraptor agents, centralised syslog, passive network capture) transforms an emergency response into a repeatable, auditable process.

REFERENCES

- [1] M. Cohen, “WinPmem: The Open Source Memory Acquisition Tool,” *Velocidex GitHub Repository*, 2023. [Online]. Available: <https://github.com/Velocidex/WinPmem>
- [2] E. Zimmermann, “KAPE: Kroll Artifact Parser and Extractor,” *Kroll*, 2019. [Online]. Available: <https://www.kroll.com/en/services/cyber-risk/incident-response-litigation-support/kroll-artifact-parser-extractor-kape>
- [3] Y. Yamato et al., “Hayabusa: Windows Event Log Fast Forensics Timeline Generator,” *Yamato Security GitHub*, 2022. [Online]. Available: <https://github.com/Yamato-Security/hayabusa>
- [4] T. Moreira, “UAC: Unix Artifact Collector,” *GitHub Repository*, 2020. [Online]. Available: <https://github.com/tclahr/uac>
- [5] J. Case, “LiME: Linux Memory Extractor,” *GitHub Repository*, 2012. [Online]. Available: <https://github.com/504ensicsLabs/LiME>
- [6] Microsoft, “AVML: A portable volatile memory acquisition tool for Linux,” *GitHub Repository*, 2023. [Online]. Available: <https://github.com/microsoft/avml>

- [7] D. Brezinski and T. Killalea, "Guidelines for Evidence Collection and Archiving," *IETF RFC 3227*, Feb. 2002.
- [8] ISO/IEC, "ISO/IEC 27037:2012: Information technology. Guidelines for identification, collection, acquisition and preservation of digital evidence," 2012.
- [9] Velocidex, "Velociraptor: Endpoint Visibility and Collection Tool," *GitHub*, 2023. [Online]. Available: <https://github.com/Velocidex/velociraptor>